HERNETIQ | WEEK 15

Regulatory Exposure Table

NovaPay AI | Companion artefact for the Week 15 compliance gap analysis

Finding	Named regulation and article	What it requires / why relevant	Evidence basis from Week 14
Customer data separation	EU AI Act, Article 15 (Accuracy, robustness and cybersecurity); Article 9 (Risk management system)	Article 15 requires appropriate cybersecurity for applicable high-risk systems throughout their lifecycle. Article 9 requires risks to be identified, evaluated and addressed.	The policy promises client data separation, but the reviewed access process does not visibly confirm that the business requesting records is the same client that signed in.
Unreviewed training data	EU AI Act, Article 10 (Data and data governance); Article 9	Article 10 sets governance and quality criteria for training, validation and testing datasets in applicable high-risk systems. Article 9 requires risk controls.	An external source is marked unreviewed, lacks integrity and bias-review status, is enabled, and is shown in the 1 October 2024 run record. This does not prove it caused an incident.
Model releases without evidenced approval	EU AI Act, Article 9; Article 43 (Conformity assessment)	Article 9 requires a documented lifecycle risk-management process. Article 43 sets the conformity-assessment route for applicable high-risk systems before market placement or putting into service; it does not automatically require reassessment for every routine retraining.	Records show automatic production updates. The reviewed release path does not evidence pre-release approval; the fraud incident root cause remains unknown.
Fairness and drift monitoring gaps	EU AI Act, Article 10; Article 9	Article 10 addresses data governance and quality; Article 9 requires a maintained process for identifying, evaluating and addressing risks over the lifecycle.	Fairness checks are incomplete, automatic alerts for significant changes in decision patterns are not configured, and two incidents remain open without established root causes.

Legal scope is not established by the reviewed records. Annex III, point 5(b), addresses systems used to evaluate the creditworthiness of natural persons or establish their credit score; this case describes SME loan applications. Legal/compliance should confirm intended use, affected persons and territorial scope before treating any EU AI Act provision as a binding obligation. References above are potential exposure areas, not a finding of a legal breach.

Official legal text: Regulation (EU) 2024/1689 (EUR-Lex). The reviewed case materials do not establish final legal classification or territorial scope.